

EduNex Production Readiness Report

Concise production-readiness evaluation

Date: 2026-09-02 17:25 IST

Scope: code-level production-readiness fixes and verification. Real payment gateway, real OTP delivery, and full credentialed login journey still require live production credentials.

Verdict

Code-level blockers fixed.

The previous dependency, HTTP security header, and old-backend-reference blockers have been fixed in the repo. Backend and frontend dependency audits now report 0 vulnerabilities.

Before flipping real production traffic, configure the live backend domain, production secrets, real OTP/payment providers, and run credentialed end-to-end tests.

Essential Test Results

Area	Result	Notes
Backend smoke API	PASS	Fresh server on port 3112 passed <code>/api/health</code> , <code>/api/health/db</code> , <code>/api/courses</code> , <code>/api/categories</code> , protected Bunny route, private image proxy target.
Frontend production build	PASS	<code>npm run build</code> completed successfully; 76 modules transformed.
Backend syntax check	PASS	Runtime <code>.js</code> / <code>.mjs</code> files passed <code>node --check</code> ; k6 scripts excluded because they run in the k6 runtime.
MongoDB index audit	PASS	20 models checked; 0 missing indexes.
Public API load check	PASS	k6 checked <code>/</code> , <code>/api/health/db</code> , <code>/api/categories</code> , <code>/api/courses</code> at 10 and 50 requests against fresh server on port 3113. 0.00% failures, 100.00% checks.
Frontend route reachability	PASS	<code>/</code> , <code>/courses</code> , <code>/courses.html</code> , <code>/dashboard</code> returned HTTP 200 locally.
Protected route blocking	PASS	<code>/api/admin/users</code> returned 401; <code>/api/bunny/videos</code> returned 401.
Image proxy SSRF check	PASS	Private localhost target was blocked with HTTP 400.
Secret file hygiene	PASS	Real <code>.env</code> files are git-ignored; only <code>.env.example</code> files are tracked.
Frontend npm audit	PASS	0 vulnerabilities.
Backend npm audit	PASS	0 vulnerabilities after removing vulnerable Firebase Admin dependency chain and adding Helmet.
App security headers	PASS	Production-mode header check shows CSP, HSTS, no-sniff, no-referrer, frame deny, and no X-Powered-By.
Old backend references	PASS	App code/config no longer references <code>api.pendulumblog.online</code> or <code>api.edunex.live</code> .

Fixed Blockers

1. Backend dependency vulnerabilities.

- `npm audit --audit-level=low` now reports 0 vulnerabilities.
- Removed `firebase-admin`, which pulled the vulnerable `@google-cloud/storage` -> `teeny-request` -> `uuid@9` chain.
- Replaced Firebase Admin usage with a direct FCM HTTP v1 sender in `services/pushService.js`.

2. App-level security headers.

- Added Helmet.
- Disabled X-Powered-By.
- Added CSP, HSTS in production, X-Content-Type-Options, Referrer-Policy, and frame protection.

3. Old backend routing.

- Vite dev/preview proxy now defaults to `http://127.0.0.1:3000`.
- `_redirects` no longer proxies `/api/*` to the old backend.
- Production hosting still needs the real live backend domain configured.

Good Signs

- Backend is not just a thin redirect layer anymore; it has real models, routes, services, DB checks, auth-protected areas, content APIs, proxy protection, and migration/test scripts.
- Current public catalog APIs are fast in the small local k6 run.
- MongoDB index coverage is clean.
- Frontend builds successfully and the basic React routes are reachable.
- No real `.env` files are tracked.

Still Required Before Live Traffic

- Configure production domain/proxy for `/api`.
- Set production secrets for MongoDB, JWTs, admin password, OTP, payment, Bunny, AI, and optional FCM.
- Run full credentialed login/auth tests with real test users.
- Run payment provider sandbox/live callback tests.
- Verify deployed DNS, SSL, CDN/cache behavior, logs, alerts, and backup/restore.

Next Action Order

1. Set the real production backend URL in the hosting provider.
2. Put real production env vars into the backend host.
3. Deploy staging first.
4. Run full login, payment, video, AI, admin, and mobile session tests.
5. Promote to production only after staging passes.